המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____
מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר
קוד קורס: 689156
תאריך הבחינה: 30/11/2025 שעת הבחינה: 09:00
שנה"ל: תשפ"ה סמסטר: קיץ מועד: מיוחד
מרצה: ד"ר מנחם ליבוביץ
משך הבחינה: 01:20 שעות

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- בכל שאלה יש לסמן את התשובה הנכונה ביותר בדף הקידוד. **רק דף הקידוד ייבדק!**
- את התשובות יש לסמן **בעט שחור או כחול כהה בלבד, באופן ברור ומודגש. יש להקפיד על כתב יד קריא וברור**
- אין לסמן על דף הקידוד ו/או שאלון הבחינה במַדְגֵּשׁ (מַרְקֵר) זוהר
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 09:20, 09:50. לזכאי תוספת זמן גם בשעה 10:20

נא **לא לשאול** את השאלות הבאות בעזרת פתקים, כי לא יינתן עליהם מענה:
- יש טעות בבחינה/בשאלה/בסעיף...
- יש יותר מתשובה אחת נכונה או אף אחת מהתשובות לא נכונה.
- לא למדנו על...
- מה התרגום של [משהו] בעברית/באנגלית...
- מה המשמעות של ראשי התיבות...
- כל שאלה שעיקרה לגרום לגילוי התשובה

חשוב מאוד:
- בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
- יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, סעיף א הוא הנכון.

<u>שאלה מספר 1:</u>

להלן פסאודו-קוד המציג פונק׳ המטפלת בצורה קריפטוגרפית במידע:

```
function foo(key_encryption, key_mac, ciphertext):
    (plaintext, received_tag) = Decrypt(key_encryption, ciphertext)
    computed_tag = ComputeMAC(key_mac, plaintext)
    if computed_tag != received_tag:
        return "Invalid!"
    else:
        return plaintext
```

מהי השיטה בשימוש על פי פסאדו-קוד זה?

א. MAC then Encrypt

ב. Encrypt then MAC

ג. Encrypt and MAC

ד. RSA

<u>שאלה מספר 2:</u>

ב TLS, נתון כי תוקף Man in the middle החליף את תעודת השרת שנשלחה אל הלקוח בתעודה חוקית, אך של אתר אחר (כלומר עם דומיין שונה מהדומיין של השרת), וצירף chain of trust תקין. מה השלב המוקדם ביותר שזה יתגלה?

א. מיד לאחר שה ServerHello הגיע ללקוח

ב. מיד לאחר שה ClientHello הגיע לשרת

ג. מיד לאחר שה ClientFinish הגיע לשרת

ד. מיד לאחר שה ClientKeyExchange הגיע לשרת

<u>שאלה מספר 3:</u>

מהי הטענה הנכונה?

א. מנגנון ה Same Origin Policy לא מונע התקפות CSRF (כלומר, עדיין ייתכנו התקפות CSRF)

ב. ב Dom based XSS הקוד הפגיע (הקוד עם החולשה) מורץ בdatabase

ג. ב Dom based XSS הקוד הפגיע (הקוד עם החולשה) מורץ בשרת

ד. מנגנון ה Same Origin Policy מונע Reflected XSS אך לא מונע Dom based XSS

<u>שאלה מספר 4:</u>

מוצע הפרוטוקול הבא, הנועד לבצע אימות לקוח מול שרת על גבי חיבור tcp רגיל:

- **לקוח שולח לשרת את השם משתמש שלו (Username) ואת תוצאת ביצוע hash על השרשור של שם המשתמש של הלקוח והסיסמא של הלקוח, כלומר:**

Hash(Username || Password)

- **השרת משווה את ערך hash שהלקוח שלח למה ששמור אצלו בבסיס הנתונים, ואם הערכים זהים, הלקוח מאומת.**

מהי הטענה הנכונה ביחס לפרוטוקול זה?

א. הפרוטוקול המוצע פגיע לתוקף Eavesdropper

ב. אין בעיה אבטחתית בפרוטוקול המוצע

ג. הפרוטוקול המוצע אינו פגיע לתוקף Eavesdropper אך פגיע לתוקף MitM

ד. הפרוטוקול המוצע בטוח בתנאי שמשתמשים בפונק׳ hash בטוחה קריפטוגרפית, למשל, SHA256

<u>שאלה מספר 5:</u>

איזו מבין הטענות הבאות נכונה?

א. בביטקוין, לא משתמשים ב One Time Pad בכדי לייצר את הארנקים

ב. בביטקוין, חובה לכרות ביטקוין בעצמנו אם אנחנו רוצים לבצע עסקאות בביטקוין

ג. ב escrow transactions, המוכר חייב לאשר את העסקה כדי שהיא תהיה חוקית

ד. בביטקוין, מנגנון ה escrow transactions מחייב כל miner ״לנעול״ בערבון מספיק ביטקוין מראש כך שאם ייתפס שהminer איפשר לתוקף לבצע double spending ינקו את הקנס מהערבון של ה miner.

<u>שאלה מספר 6:</u>

עבור n=23 ו g=3, אליס ובוב הריצו את פרוטוקול דיפי הלמן. במהלך הרצת הפרוטוקול, אליס שלחה לבוב את המספר 13 ובוב שלח לה את המספר 4. מה מהבאים יכול להיות המספר הסודי המשותף שנבחר בסוף התהליך?

א. 12

ב. 18

ג. 17

ד. 10

<u>שאלה מספר 7:</u>

איזה טענה <u>אינה</u> נכונה?

א. מנגנון Signed Certificate Timestamp (SCT) נועד לפתור בעיית פרטיות הקיימת במנגנון ה OCSP

ב. מנגנון CT ומנגנון CRL פותרים בעיות שונות

ג. מנגנון CT ומנגנון OCSP פותרים בעיות שונות

ד. מנגנון CT בא לידי ביטוי בתעודות על ידי ערכי ה SCT

<u>שאלה מספר 8:</u>

מה מבין הבאים היא ההגדרה של תכונת ה collision resistance? (שימו לב, השאלה מבקשת collision resistance <u>ולא</u> מבקשת weak collision resistance)

א.

It is hard to find messages $m_0 \neq m_1$ such that $h(m_0) = h(m_1)$

ב.

Given a digest d of a random message, it is hard to find a message m such that d = h(m)

ג.

Given a random message m_0, it is hard to find a message m_1 that is not equal to m_0 such that $h(m_0) = h(m_1)$

ד.

It is hard to find messages $m_0 \neq m_1$ such that $h(m_0) \neq h(m_1)$

<u>שאלה מספר 9:</u>

אלגוריתם 3DES יכול לתמוך אחורה בהצפנת DES. נתונים שלושה מפתחות K1, K2, K3. כיצד מוגדרת פעולת ההצפנה ב 3DES שתאפשר הצפנה גם עבור 3DES וגם תאפשר תמיכה אחורה בצופן DES המקורי?

א. $C = Enc_{K3}(Dec_{K2}(Enc_{K1}(m)))$

ב. $C = Dec_{K1}(Enc_{K2}(Enc_{K3}(m)))$

ג. $C = Dec_{K1}(Dec_{K2}(Dec_{K3}(m)))$

ד. $C = Enc_{K3}(Dec_{K2}(Dec_{K1}(m)))$

<u>שאלה מספר 10:</u>

נתון עץ מרקל המכיל 1000 עלים. אם נשנה רק עלה אחד בעץ, כמה קודקודים (צמתים) שאינם עלים ישתנו כתוצאה מכך?

א. רק הצמתים בנתיב מהעלה שהשתנה ועד לשורש העץ (כולל) ישתנו

ב. רק הצומת אב (הישירה בלבד) של העלה שהשתנה

ג. כל הצמתים בעץ (שאינם עלים) חוץ מהשורש

ד. כל הצמתים בעץ (שאינם עלים) כולל השורש

--- סוף המבחן ---